

SENTINEL

Kiến trúc Nhận thức Hai tầng cho Phát hiện & Phản hồi Mỗi đe dọa Tự động sử dụng AI Tác tử (Agentic AI)

Học viên: Nguyễn Đức Bình

GVHD: TS. Bùi Văn Hiếu · TS. Đặng Văn Hiếu

Trường Đại học FPT – Thạc sĩ Kỹ thuật Phần mềm (MSE) · 2026

Bối cảnh & Vấn đề

- **Trung tâm Điều hành An ninh (SOC)** ngập trong cảnh báo → **mệt mỏi cảnh báo (alert fatigue)** → bỏ sót **APT** nguy hiểm.
- Hai hướng tiếp cận hiện có đều có **giới hạn cố hữu**:

Hướng	Ưu	Nhược
Luật tĩnh (rule/signature)	Nhanh, tất định	Bỏ sót zero-day , không hiểu ngữ cảnh
Đưa mọi log vào LLM	Suy luận sâu	Trễ 4-6 giây/log , không mở rộng, rủi ro bị thao túng

“ **Khoảng trống**: chưa có kiến trúc kết hợp *tốc độ tất định* với *suy luận LLM có kiểm soát & an toàn*. ”

Câu hỏi & Mục tiêu nghiên cứu

Câu hỏi: Làm thế nào để tự động hoá SOC vừa **nhANH ở tốc độ mạng**, vừa **suy luận sâu có căn cứ**, mà LLM **không trở thành điểm yếu bảo mật**?

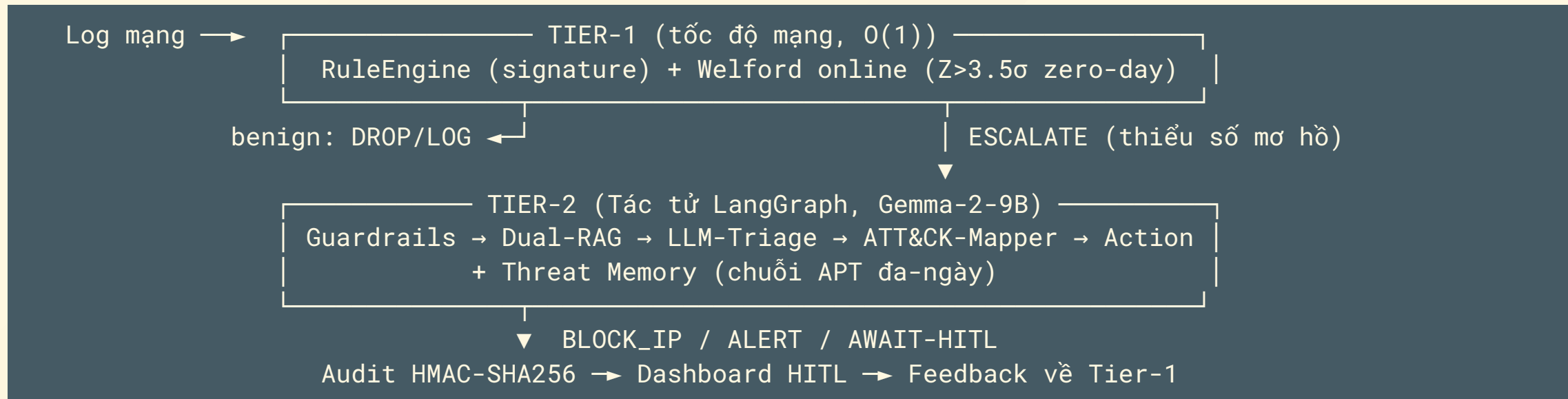
Mục tiêu:

1. Loại bỏ lượng hành tính ở **tốc độ mạng, $O(1)$** – chỉ leo thang phần *thực sự mơ hồ* cho LLM.
2. Suy luận **có nền tảng (grounded)** bằng tri thức chuẩn (MITRE ATT&CK + NIST).
3. **Cô lập LLM** khỏi thao túng đối kháng bằng rào chắn mật mã.
4. Đánh giá **ngiên ngặt, tái lập, trung thực** (khung 5 chiều + kiểm định thống kê).

Đóng góp chính

1. **Kiến trúc 2 tầng** – Tier-1 lọc tất định tốc độ mạng ↔ Tier-2 tác tử LangGraph.
2. **Bộ lọc Welford trực tuyến** phát hiện zero-day thống kê ở **$O(1)$** RAM/CPU.
3. **Dual-RAG** (FAISS + BM25 + RRF) nền tảng hoá suy luận trên MITRE + NIST.
4. **Rào chắn AI phòng thủ chiều sâu** + đồng thuận Tier-1/Tier-2 chống thao túng ngữ nghĩa.
5. **Lớp ánh xạ MITRE ATT&CK có cấu trúc** (đóng góp bổ sung – node thứ 6).
6. **Khung đánh giá 5 chiều + kiểm định thống kê** (McNemar, Mann-Whitney U, Wilson CI, LLM-as-Judge liên-họ).

Kiến trúc tổng quan



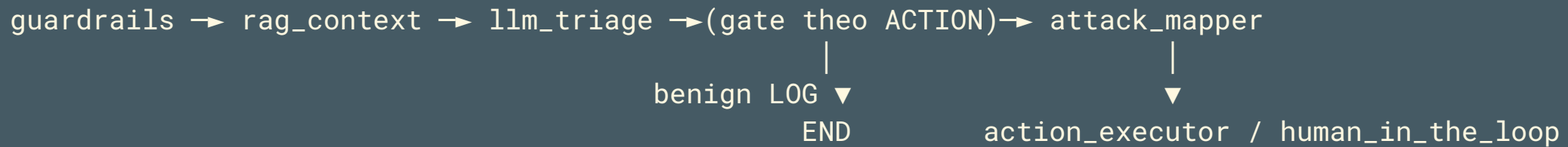
- **Tách đường chặn đồng bộ:** Tier-1 đã chặn tấn công rõ ràng ở tốc độ mạng; LLM đóng góp **giải thích + tương quan bất đồng bộ** → nhẽn LLM **không** làm chậm bảo vệ.

Tier-1 – Lọc tốc độ cao (tất định)

- **RuleEngine:** so khớp chữ ký WAF (SQLi/XSS/Path/Cmd-Inj), injection/jailbreak, cổng nhạy cảm, port-scan.
- **Welford online** (`RunningStats`): cập nhật Mean/StdDev **$O(1)$** ; `$Z > 3.5\sigma$` $\Rightarrow$ **zero-day thống kê** (mà signature bỏ sót).
- **Chống Baseline Poisoning:** chỉ nạp flow *lành tính* vào thống kê nền; hot-reload cấu hình mỗi 5s.
- **Session Baseline:** hồ sơ IP, phát hiện port-scan (>10 cổng), TTL eviction chống tràn RAM.

“ **Quyết định trong ~0.6 ms** so với **4–6 s** của một lượt suy luận LLM. ”

Tier-2 – Tác tử LangGraph (6 nút)



- **State Machine tất định** (`@dataclass SentinelState`) – chống *semantic drift* bằng trường IOC *chỉ-append*.
- **Suy biến an toàn:** LLM chết → tự đẩy về `AWAIT_HITL`, đồ thị **không vỡ** (Tier-1 vẫn bảo vệ độc lập).
- **Tất định:** `temperature=0.1` + `seed=42` → cùng prompt cho **cùng phán quyết** (tái lập).

Dual-RAG – Suy luận có nền tảng

- Truy xuất **kép**: **MITRE ATT&CK** (299 kỹ thuật) + **NIST SP 800-61r2** (playbook ứng cứu).
- **Hybrid Search**: Dense **FAISS** (ngữ nghĩa) + Sparse **BM25** (từ khoá) → hợp nhất bằng **Reciprocal Rank Fusion (RRF, k=60)**.
- **Semantic Cache** (LRU, TTL 1800s) giảm độ trễ cho truy vấn lặp.
- **Chống RAG Poisoning**: kiểm **checksum SHA-256** tài liệu + `sanitize_retrieve` + gắn *provenance* trước khi vào prompt.

“ Ràng buộc LLM vào **ngữ cảnh đã xác thực** ⇒ giảm ảo giác (hallucination). ”

Rào chắn AI – Phòng thủ chiều sâu

- **Delimited Data Encapsulation** – bọc log bằng **nonce một-lần** (`secrets.token_hex`), chống *delimiter smuggling*.
- **Encoding Neutralizer** – giải Base64/Hex/URL/homoglyph trước khi phân tích.
- **Output Sanitizer** – chặn *data exfiltration* qua markdown/HTML/base64 trong đầu ra LLM.
- **Lá chắn Đồng thuận Tier-1/Tier-2** – nếu Tier-1 (tất định) coi là tấn công mà LLM hạ xuống "benign" ⇒ ép `AWAIT_HITL` (LLM **không thể** bị "nói chuyện" hạ cấp như con người).
- **Audit HMAC-SHA256 móc-xích** – phát hiện giả mạo log pháp y.

Đóng góp mới: Lớp ánh xạ MITRE ATT&CK

Vấn đề: triage chỉ xuất *nhân tự do* ("SQLi detected") → khó dùng cho SOC.

Giải pháp: node `attack_mapper` biến thành **bản ghi có cấu trúc, kiểm chứng được:**

```
{ "attack_type": "SQL Injection", "mitre_tactic": "Initial Access",  
  "mitre_technique": "T1190 - Exploit Public-Facing Application",  
  "mitre_url": "https://attack.mitre.org/techniques/T1190/",  
  "recommended_response": "Chặn IP tại WAF + leo thang HITL" }
```

- **3 đường:** curated (web-attack, tất định) → **neo vào verdict triage** → RRF+LLM (fallback).
- **Trung thực:** Prompt Injection → **MITRE ATLAS** (không phải Enterprise); IDOR không có kỹ thuật riêng.

Threat Memory & Phát hiện APT đa-ngày

- **Bộ nhớ dài hạn** (SQLite): uy tín IP, thực thể nội bộ, chỉ báo APT – **inject vào prompt** để Agent biết *lịch sử*.
- **Tương quan APT EMERGENT**: IP xuất hiện ở **≥ 2 NGÀY tấn công** phân biệt $\Rightarrow$ ghép thành **chuỗi kill-chain đa-ngày**.
- Chống **low-and-slow**: liên kết các hành vi đơn lẻ cách nhau nhiều ngày mà signature đơn-điểm bỏ sót.

“ Khôi phục **3/3 chiến dịch APT** (DAPT2020), **recall = 1.0**, **specificity = 1.0** (0 báo nhầm). ”

Phương pháp Đánh giá – Khung 5 chiều (5D)

Chiều	Chỉ số vận hành
Accuracy	Precision / Recall / F1 · APT recall · zero-day
Performance	Độ trễ Tier-1 vs Tier-2 · tỷ lệ leo thang
Security	Tỷ lệ kháng adversarial (tĩnh vs full-pipeline)
Explainability	LLM-as-Judge liên-họ (RAGAS) · độ đầy đủ audit
Integrity	Xác thực chuỗi HMAC

- **Kiểm định thống kê:** McNemar, **Mann-Whitney U**, **Wilson 95% CI**.
- **Dữ liệu THẬT:** CSE-CIC-IDS2018 + DAPT2020 · **tất định** (seed=42) · **isolation** không đụng dữ liệu luận văn.

Kết quả 1 – Hiệu năng

- **Độ trễ Tier-1: ~0.6 ms** ↔ **Tier-2 (LLM): 4–6 s** — tách biệt được kiểm định **Mann-Whitney U** ($p = 2.8 \times 10^{-17}$).
- **Giảm độ trễ đầu-cuối 82.97%**: LLM-only **26.9 s** → Two-Tier **4.6 s** (mục tiêu $\geq 60\%$).
- **Kiểm soát ngữ cảnh**: nén Drain **bão hoà ~80 token** bất kể số log (RAW vượt cửa sổ 8192 tại $N \approx 100$).

“ Tier-1 giải quyết **~91%** lưu lượng $\Rightarrow$ chỉ **~9%** phải gọi LLM. ”

Kết quả 2 – Độ chính xác

- **Phân loại (Unified Stream):** $F1 = 0.594$ · Precision = **0.939** · Recall = **1.0**.
- **APT đa-ngày:** **3/3** chiến dịch · recall **1.0** · specificity **1.0**.
- **Zero-day:** Welford bắt **7/7** ngoại lệ signature-less mà engine tĩnh **bỏ sót**.

Ghi chú trung thực: Precision cao (0.94) nhưng Recall/F1 phản ánh việc Tier-1 ưu-tiên-precision (đánh đổi có chủ đích); giá trị kiến trúc nằm ở suy luận có ngữ cảnh + APT + zero-day, không chỉ ở phân loại nhị phân.*

Kết quả 3 – Bảo mật & Tính giải thích

- **Kháng đối kháng (full-pipeline, LLM + Consensus Guard): 100%** (0 bị chiếm quyền).
- **Rào chắn tĩnh (120 payload OWASP):** chặn **100% encoding-bypass**; **~50%** tổng thể – phần *ngữ nghĩa* còn lại được **lá chắn đồng thuận** đẩy về HITL.
- **LLM-as-Judge liên-họ** (Llama-3 chấm Gemma-2): tổng **3.91/5**; **Faithfulness 4.00/5** (kết luận bám chứng cứ RAG).

“ Phòng thủ **chiều sâu**, không phải một biểu thức regex đơn lẻ. ”

Kết quả 4 – Lớp ánh xạ ATT&CK

Chế độ đánh giá	n	Khớp technique	Tactic
Unit (10 web-attack, curated)	—	100%	—
Web-payload – pipeline triển khai	50	64.0%	57.5%
Web-payload – chỉ truy xuất (rrf)	50	62.0%	52.5%
Flow-only GT – pipeline triển khai	160	0.0%	3.6%

- **Trung thực:** 0% trên flow-only là **giới hạn của bài toán** (ill-posed) – nhãn cơ học $\neq$ suy luận LLM; **không phải lỗi mapper**.
- Signature attacks: Prompt-Inj & Cmd-Inj **100%**, XSS & Path-Trav 80%.

Ablation Study – Đóng góp từng tầng

- Tập **cân bằng 150 benign / 150 tấn công** (tránh base-rate làm mọi cấu hình co về "toàn-dương").

Cấu hình	Precision	Recall	Độ trễ
B – LLM thuần (không lọc/RAG/chặn)	0.508	0.867	6.50 s
C – + cổng Welford	0.627	0.493	0.59 s

- Cổng Welford:** precision **0.508** → **0.627**, độ trễ **giảm ~11 lần** – đánh đổi có chủ đích với recall.
- McNemar** (B vs mọi cấu hình có cổng): **$p < 0.001$** (138 phán quyết bất đồng một chiều).

Hạn chế (nêu thẳng)

- **Ánh xạ ATT&CK từ flow-only** là bài toán **ill-posed** — hiệu quả ở miền có payload/ngữ nghĩa, không ở telemetry luồng thuần.
- **Cỡ mẫu APT nhỏ** ($n=3$) → báo bằng **Wilson 95% CI**, cần dữ liệu APT lớn hơn.
- **Enforcement là [FIREWALL MOCK]** (ghi audit) — thực thi thật giao cho luật ACTIVE ở Tier-1; chưa tích hợp firewall sản xuất.
- **Dataset** CSE-CIC-IDS2018 (2018) — cần dữ liệu mỗi đe dọa mới hơn.

Hướng phát triển

- **Threat intel nội bộ:** nạp TTP nhóm APT thực tế (vd Mustang Panda / PlugX từ MITRE **G0129**) vào RAG.
- **Mở rộng đa-nguồn → Agentic XDR:** thêm DNS / EDR / PAM (đã sẵn kiến trúc Redis Streams đa-queue).
- **Tinh chỉnh (fine-tune) Gemma** trên dữ liệu tấn công đặc thù (LoRA/QLoRA) khi có HPC.
- **Tích hợp SOAR** (XSOAR): SENTINEL *cấp intelligence* cho playbook tự động.

Kết luận

- **SENTINEL** chứng minh: ghép **bộ lọc tất định tốc độ mạng** với **tầng AI tác tử được cô lập mật mã** cho ra giải pháp **mở rộng được & an ninh hoá**.
 - **Số liệu chốt:** độ trễ **-82.97%** ($p=2.8 \times 10^{-17}$) · APT **3/3** · zero-day **7/7** · suy luận **3.91/5** · ATT&CK mapper **64%** (miền web).
 - **Kỹ thuật vững: 207 test** pass · tất định (seed 42) · đánh giá **trung thực** (nêu cả kết quả âm).
- “ **Đóng góp:** một khuôn mẫu hai-tầng *có thể mở rộng, giải thích được, an toàn* cho phòng thủ mạng hiện đại. ”

Xin cảm ơn Hội đồng!

Em xin lắng nghe câu hỏi & góp ý

Nguyễn Đức Bình — MSE, FPT University, 2026

SENTINEL · Kiến trúc Nhận thức Hai tầng · Agentic AI